Gramm-Leach-Bliley Act (GLBA)

INSTRUCTIONS:
Please respond to each question by placing an "X" in the "Yes", "No" or "N/A" column or by providing the information requested. Use the "Tab" key to move between items. Use the "Additional information" field for explanatory comments, if necessary. If an item does not have an "Additional information" field, and you need to explain your answer, use the space at the end of the questionnaire and reference the item being explained, e.g. RE: Item 1.2-This is the explanation.

Questionnaire completed by: _____

Contact number for follow-up questions: _____

Date Completed: _____

1. Information Security Coordinator/Committee

Number	Question	Yes	No	N/A
1.1	Has an Information Security Program Coordinator or Committee been appointed who is responsible for oversight of the program and who addresses issues concerning information security and the credit union's information security program? Additional information: _____	☐	☐	☐

2. Information Security Program

Number	Question	Yes	No	N/A
2.1	Has the organization developed a formal Information Security Program that defines its plan to safeguard and protect credit union and member information and credit union systems? Additional information: _____	☐	☐	☐
2.2	Has the current Information Security Program been reviewed and approved by the Board of Directors? *If the format of the Information Security Program does not include an approval page with Board of Director signatures, please furnish a copy of the Board minutes in which the Information Security Program was approved.* Additional information: _____	☐	☐	☐
2.3	Has the program been implemented? Additional information: _____	☐	☐	☐

Number	Question	Yes	No	N/A
2.4	Is the program regularly updated? *Please provide evidence that the program is regularly updated. This evidence may be in the form of a change or history log for the document or previous versions of the document.* Additional information: _____	☐	☐	☐
2.5	Does the current Information Security Program include the following safeguards for data and systems:			
2.5.1	Administrative	☐	☐	☐
2.5.2	Technical	☐	☐	☐
2.5.3	Physical	☐	☐	☐

3. Risk Assessment

Number	Question	Yes	No	N/A
3.1	Does the Information Security Program address the credit union's Risk Assessment Methodology? Additional information: _____	☐	☐	☐
3.2	Does the Risk Assessment Methodology address anticipated and potential security threats and privacy risks? Additional information: _____	☐	☐	☐
3.3	Does the credit union conduct a formal Risk Assessment at least every two years? Additional information: _____	☐	☐	☐
3.4	Are there written and approved policies and procedures for risk remediation and/or mitigation? Additional information: _____	☐	☐	☐
3.5	Are risk exposures prioritized? Additional information: _____	☐	☐	☐
3.6	Are risk exposure, remediation and/or acceptance strategies documented? Additional information: _____	☐	☐	☐

4. Incident Response

Number	Question	Yes	No	N/A
4.1	Is there a written and approved Incident Response Plan? Additional information: _____	☐	☐	☐
4.2	Is the Incident Response Plan tested at least annually? Additional information: _____	☐	☐	☐

Number	Question	Yes	No	N/A
4.3	Have credit union personnel read, and do they understand, the credit union's Incident Response Plan? Additional information: _____	☐	☐	☐
4.4	Have Senior Management and the Board of Directors reviewed and approved the current Incident Response Plan? Additional information: _____	☐	☐	☐

5. Employee Training and Awareness

Number	Question	Yes	No	N/A
5.1	Is Security Awareness Training conducted annually? Additional information: _____	☐	☐	☐
5.2	Have employees read, and do they understand, the credit union's Information Security Program and their individual roles in protecting member information? Additional information: _____	☐	☐	☐
5.3	Have employees read, and acknowledged their acceptance of, credit union Information Security Policies and Procedures? Additional information: _____	☐	☐	☐

6. Third Party/Vendor Oversight

Number	Question	Yes	No	N/A
6.1	Are there written and approved policies and procedures addressing the management of 3rd party agreements and vendor support services? Additional information: _____	☐	☐	☐
6.2	Are service providers and vendors who transmit, maintain and/or are exposed to member information, required within their current contracts to maintain appropriate safeguards to ensure the confidentiality, availability and integrity of that information? Additional information: _____	☐	☐	☐

7. Risk Management and Control

Number	Question	Yes	No	N/A
7.1	Has the credit union implemented physical and logical access controls, including controls to authenticate and permit access to only authorized personnel, on information systems containing member information? Additional information: _____	☐	☐	☐

Number	Question	Yes	No	N/A
7.2	Does the credit union utilize physical access controls to limit access to physical facilities (i.e. computer center, offices, etc.) and record retention spaces permitting access only to authorized personnel? Additional information: _____	☐	☐	☐
7.3	Are there written and approved policies and procedures addressing production system and network change control, ensuring system modifications are initiated and completed in accordance with the credit union's information security program? Additional information: _____	☐	☐	☐
7.4	Are there written and approved dual control procedures, segregation of duties and employee background checks for personnel who have access to member information and credit union information systems? Additional information: _____	☐	☐	☐
7.5	Has the credit union implemented procedures and systems to detect actual and/or attempted attacks/intrusions into information systems containing member information? Additional information: _____	☐	☐	☐
7.6	Has the credit union implemented safeguards to protect member information against destruction, loss or damage resulting from environmental hazards such as, fire and water and/or technological failure? Additional information: _____	☐	☐	☐

8. Information Security Program Evaluation

Number	Question	Yes	No	N/A
8.1	Do the credit union's Information Security Coordinator/Committee and Senior Management meet at least annually to evaluate the credit union's Information Security Program? Additional information: _____	☐	☐	☐
8.2	Does the credit union test key controls, systems and procedures of the information security program? Additional information: _____	☐	☐	☐
8.2.1	If yes, are tests conducted and reviewed by staff independent of IT or by independent third parties? Additional information: _____	☐	☐	☐

9. Information Privacy

Number	Question	Yes	No	N/A
9.1	Has the organization developed a formal Privacy Policy that:			
9.1.1	informs members of the information collected by the credit union Additional information: _____	☐	☐	☐
9.1.2	informs members of the information disclosed by the credit union Additional information: _____	☐	☐	☐
9.1.3	informs members of the policies and procedures implemented to secure and protect the confidentiality of member information Additional information: _____	☐	☐	☐
9.2	Has the current Privacy Policy been reviewed and approved by the Board of Directors? *If the format of the Privacy Policy does not include an approval page with Board of Director signatures, please furnish a copy of the Board minutes in which the Privacy Policy was approved.* Additional information: _____	☐	☐	☐
9.3	Has the Privacy Policy been implemented? Additional information: _____	☐	☐	☐
9.4	Is the Privacy Policy regularly updated? *Please provide evidence that the policy is regularly updated. This evidence may be in the form of a change or history log for the document or previous versions of the document.* Additional information: _____	☐	☐	☐
9.5	Has the credit union created appropriate "opt out" notices for disclosure of non-public information to nonaffiliated third-parties? Additional information: _____	☐	☐	☐
9.5.1	Have "opt out" notices been implemented? Additional information: _____	☐	☐	☐
9.5.2	Are "opt-out" notices freely available to members? Additional information: _____	☐	☐	☐
9.5.3	How are "opt-out" notices made available to members? _____			

10. Consolidated Request List

Number	Requested Item	Provided	Not Provided	Reason not provided
10.1	Information Security program Coordinator/Committee Policy	☐	☐	_____
10.2	Information Security Program Policy	☐	☐	_____
10.3	Risk Assessment Policy	☐	☐	_____
10.4	Incident Response Policy	☐	☐	_____
10.5	Security Awareness Training Policy	☐	☐	_____
10.6	3rd party/Vendor Management Policy	☐	☐	_____
10.7	Access Control Policy	☐	☐	_____
10.8	Configuration/change Management Policy	☐	☐	_____
10.9	Patch Management Policy	☐	☐	_____
10.10	Segregation/Separation of Duties Policy	☐	☐	_____
10.11	Mandatory Vacation Policy	☐	☐	_____
10.12	IDS/Firewall Policy	☐	☐	_____
10.13	Disaster Recovery Policy	☐	☐	_____
10.14	Board approval for Information Security Program	☐	☐	_____
10.15	Board approval for Incident Response Program	☐	☐	_____
10.16	Forms from 10 randomly selected current employees showing their acknowledgement and acceptance of policies and procedures	☐	☐	_____
10.17	Forms from 10 randomly selected current employees showing their acknowledgement and acceptance of the organization's incident response plan	☐	☐	_____
10.18	3rd party agreements for Core Processing vendor	☐	☐	_____
10.19	3rd party agreements for Firewall/IDS vendor	☐	☐	_____
10.20	Previous Information Security Program documentation & reports	☐	☐	_____
10.21	Previous Incident Response program testing documentation & reports	☐	☐	_____

11. Additional Information for the Auditor on Gramm-Leach-Bliley Act Compliance